

"Salla Store" E-commerce Project

Case Study:

First: Organizational Controls

This section details the foundational management and structural controls essential for establishing a robust Information Security Management System (ISMS) within "Salla Store." These controls ensure that information security is integrated into the organization's governance and operational framework.

1.1. Control (5.1): Policies for Information Security

- **Description of Application in "Salla Store":** "Salla Store" is committed to establishing a comprehensive suite of information security policies that serve as the bedrock of its ISMS. These policies will be meticulously developed to cover all critical aspects of information security, encompassing user behavior, data handling, system access, and incident management. They will be regularly reviewed and updated to reflect changes in the threat landscape, technological advancements, and business operations. Furthermore, these policies will rigorously adhere to all relevant consumer protection laws and electronic transaction regulations pertinent to the regions where "Salla Store" operates, ensuring legal and regulatory compliance.
- **Process:** The process for policy management involves a structured lifecycle: initiation, drafting, review by relevant stakeholders (including legal and compliance teams), formal approval by senior management, effective communication to all affected personnel, and a predefined schedule for periodic review and necessary amendments. This iterative process ensures that policies remain current, relevant, and enforceable.
- **Required Evidence:**
 - **Approved Policy Documents:** Formally endorsed documents (e.g., PDF files or controlled internal documents) bearing the explicit approval of senior management, such as the CEO or Head of Information Security.
 - **Communication Records:** Comprehensive documentation demonstrating that policies have been effectively disseminated to all employees. This may include email distribution lists, notifications via the employee management system, mandatory acknowledgment receipts, or records of employee attendance at policy awareness training sessions.
 - **Policy Review Logs:** A meticulously maintained schedule detailing the review dates for each policy, identifying the reviewers involved, and documenting any modifications made, along with the rationale for those changes.

1.2. Control (5.2): Information Security Roles and Responsibilities

- **Description of Application in "Salla Store":** "Salla Store" will clearly define and formally assign specific information security roles and responsibilities across all levels of the organization to ensure accountability and effective security governance. A dedicated Information Security Officer (CISO or Information Security Manager) will be appointed to lead the ISMS. Information security responsibilities will be granularly defined for each department, ensuring that every team understands its contribution to the overall security posture.

- **Development Team:** Primarily responsible for integrating security into the software development lifecycle, including writing secure code, conducting static and dynamic code analysis, and performing penetration testing.
- **Operations Team:** Accountable for the secure configuration and maintenance of servers, network infrastructure, data backup and recovery processes, and continuous monitoring of system security.
- **Customer Service Team:** Responsible for the secure handling of customer data, adherence to privacy protocols, and prompt reporting of any suspected security incidents.
- **Senior Management:** Holds ultimate responsibility for providing the necessary resources, strategic direction, and unwavering support for the ISMS, fostering a security-first culture.
- **Process:** The process involves a systematic approach to defining, documenting, communicating, and regularly reviewing roles and responsibilities. This includes developing job descriptions, establishing clear reporting lines, and ensuring that all personnel are adequately trained and aware of their security obligations.
- **Required Evidence:**
 - **Role Descriptions:** Detailed documents outlining the specific information security tasks and responsibilities for each job role within the organization.
 - **Organizational Charts:** Visual representations of the management hierarchy that explicitly depict reporting relationships and allocated security responsibilities within "Salla Store's" structure.
 - **Acknowledgement Forms:** Signed documents from employees confirming that they have read, understood, and accepted their information security policies and responsibilities.
 - **Training Records:** Comprehensive records of employee attendance and completion of security awareness training sessions, specifically highlighting their understanding of assigned security responsibilities.

1.3. Control (5.3): Segregation of Duties

- **Description of Application in "Salla Store":** "Salla Store" will implement the principle of segregation of duties to mitigate the risk of fraud, errors, or unauthorized actions by ensuring that no single individual has complete control over a critical process or access to sensitive assets. This involves distributing incompatible responsibilities among different individuals or teams. Where complete segregation is impractical (e.g., in smaller teams), "Salla Store" will implement robust compensating controls.
 - **Examples of Segregation:**
 - The individual responsible for developing software code will be distinct from the individual authorized to deploy that code to the production environment.
 - Personnel processing customer orders will not possess direct administrative access to sensitive credit card databases, as these are typically handled by the payment gateway.

- The administrator responsible for user account management and permission granting will not have unfettered administrative access to all systems.
- **Compensating Controls:** If complete segregation is not feasible, compensatory measures such as the "Four-eyes principle" (requiring approval from a second independent party) or detailed, regularly reviewed audit logs will be implemented to provide an equivalent level of control.
- **Process:** The process involves identifying potential conflicts of interest within job roles, designing workflows to incorporate segregation, and, where necessary, designing and implementing compensating controls. Regular reviews of access rights and audit trails will ensure compliance.
- **Required Evidence:**
 - **Segregation of Duties Policy:** A formal document outlining the guiding principles and specific requirements for the segregation of duties within "Salla Store."
 - **Access Control Logs:** Systemic, tamper-proof records detailing who has accessed which system or data, and who has performed specific actions. These logs are crucial for audit trails.
 - **Audit Reports:** Internal or external reports providing an independent verification of the implementation of the segregation of duties policy, highlighting any identified violations, control weaknesses, or potential loopholes.
 - **Roles and Permissions Matrix:** A comprehensive table that clearly maps organizational roles to the specific permissions and access rights granted within various systems, illustrating adherence to segregation principles.

1.4. Control (5.4): Management Responsibilities

- **Description of Application in "Salla Store":** Senior management at "Salla Store" is unequivocally committed to actively supporting and championing information security across the entire organization. Their responsibilities extend beyond mere approval to active involvement in resource allocation, oversight, and fostering a pervasive security-conscious culture. This commitment includes:
 - **Resource Allocation:** Ensuring the allocation of necessary financial and human resources for information security initiatives, including security tool procurement, specialized training programs, and the recruitment of skilled cybersecurity professionals.
 - **Oversight and Review:** Active participation in periodic information security reviews to assess the performance of the ISMS, review security metrics, and make informed decisions.
 - **Issue Resolution:** Promptly addressing and resolving escalated security issues, demonstrating a proactive approach to risk management.
 - **Culture Promotion:** Leading by example in fostering a robust security awareness culture among all employees, emphasizing the importance of individual accountability in protecting information assets.

- **Process:** Management responsibilities are discharged through regular leadership meetings, dedicated security review sessions, communication channels for security updates, and active participation in incident response planning and post-incident reviews.
 - **Required Evidence:**
 - **Management Meeting Minutes:** Official minutes documenting discussions held during senior management meetings regarding information security, including budget allocations, resource approvals, and ISMS performance reviews.
 - **Resource Allocation Records:** Documentation proving the dedicated allocation of financial and human resources to information security activities (e.g., invoices for security software licenses, employment contracts for security personnel, training budgets).
 - **ISMS Performance Reports:** Regular, comprehensive reports presented to senior management summarizing the current security posture, detailing security incidents, reporting on compliance status, and evaluating the effectiveness of implemented controls.
 - **Security Policy Statement Document:** A formal statement issued and endorsed by senior management, unequivocally affirming their commitment to information security and its critical importance to the achievement of "Salla Store's" business objectives.
-

Second: Data Protection Controls

This section outlines "Salla Store's" commitment to advanced data protection measures, ensuring the confidentiality, integrity, and availability of sensitive information throughout its lifecycle, from creation to secure deletion.

2.1. Control (8.10): Information Deletion

- **Control:** "Are secure methods implemented to delete information when no longer required?"
- **Description of Application at "Salla Store":** Given "Salla Store's" extensive handling of customer data, including order details, payment information, and shipping data, it is paramount to establish and enforce clear policies and procedures for the secure and irreversible deletion of data. This applies once the data's retention purpose has concluded or upon the expiration of legal or regulatory retention periods (e.g., for very old transaction records or information pertaining to permanently closed customer accounts). The scope of secure deletion encompasses data residing in databases, backup systems, server logs, and all other forms of storage media. "Salla Store" will utilize industry-standard secure deletion tools and techniques to guarantee that deleted data cannot be subsequently recovered or reconstructed.
- **Process:** The process involves a defined procedure for identifying data no longer required, selecting appropriate secure deletion methods based on data sensitivity and storage medium, executing the deletion, and verifying its successful completion. For instance, data overwriting techniques will be employed for hard drives, secure deletion commands for database records, and physical destruction (shredding or degaussing) for deprecated physical media.
- **Required Evidence:**

- **Deletion Policies:** A formal, documented policy specifying the criteria for data deletion (e.g., retention periods, end of purpose), the roles responsible for deletion, and the approved, secure methods for various data types and storage media.
- **Logs of Deletion Activities:** Detailed, auditable records documenting each deletion operation, including the date and time, the type and volume of data deleted, the specific method employed (e.g., "3-pass overwrite," database command), and the personnel who initiated or performed the deletion.
- **Verification Records:** Reports or test results confirming the success and completeness of data deletion. This may include outputs from data recovery verification tools, post-deletion integrity checks, or minutes from reviews confirming the absence of recoverable data.

2.2. Control (8.11): Data Masking

- **Control:** "Is data masking used to protect sensitive information in non-production environments?"
- **Description of Application at "Salla Store":** "Salla Store" recognizes the inherent risk of exposing sensitive production data in non-production environments (such as development, testing, or training). While these environments often require realistic data for effective functional and performance testing, they must not contain actual, sensitive customer information. Therefore, "Salla Store" will rigorously implement data masking or data anonymization techniques. This process involves transforming sensitive data elements (e.g., actual credit card numbers, customer names, email addresses) into fictitious or altered values that maintain data format and realism for testing purposes but cannot be reverse-engineered to reveal the original identity.
- **Process:** The process for data masking involves identifying sensitive data fields, selecting appropriate masking techniques (e.g., substitution, shuffling, encryption with a one-way hash, nulling), applying these techniques using specialized tools or custom scripts, and verifying the effectiveness of the masking.
- **Required Evidence:**
 - **Data Masking Policies:** A clear document outlining the policy for data masking, specifying when and why it is applied, the types of data that must be masked, the permissible masking techniques, and the non-production environments where it is mandatory.
 - **Implementation Reports:** Documents detailing the execution of data masking processes, including specifications of the data masking tools or scripts used, the specific datasets that were masked, and the configuration parameters applied.
 - **Testing Logs:** Records from quality assurance and security testing confirming that sensitive data in non-production environments has been correctly masked and does not expose real, identifiable information.

2.3. Control (8.12): Data Leakage Prevention (DLP)

- **Control:** "Are measures in place to prevent unauthorized exfiltration of data?"

- **Description of Application at "Salla Store":** Unauthorized data leakage, particularly of customer data or proprietary intellectual property, represents one of the most significant and potentially damaging risks to "Salla Store." To proactively mitigate this threat, "Salla Store" will implement robust Data Leakage Prevention (DLP) solutions. DLP tools will be deployed across critical egress points of "Salla Store's" network and on employee endpoints. These tools are designed to monitor, detect, and prevent sensitive data (e.g., credit card numbers, national ID numbers, customer email addresses) from leaving the organization via unauthorized channels such as email, USB drives, unapproved cloud storage services, or other means.
- **Process:** The process involves the strategic deployment of DLP tools, defining sensitive data types and associated rules, continuous monitoring of data flows, and establishing automated or manual response actions upon policy violation detection. DLP tools will be integrated into "Salla Store's" IT infrastructure to monitor data movement across the network and on individual employee computers.
- **Required Evidence:**
 - **DLP Tool Configurations:** Comprehensive documentation, including screenshots or detailed configuration files, illustrating the precise settings and rules applied to the DLP tools. This should include defined sensitive data patterns, user groups, and permitted/prohibited data transmission channels.
 - **Incident Reports:** Formal reports documenting any detected data leakage attempts or policy violations by the DLP system. These reports should include full details of the incident, the specific data involved, the automated or manual actions taken (e.g., block, quarantine, alert), and the outcomes of subsequent investigations.
 - **Monitoring Logs:** Regular, detailed logs generated by the DLP tools, providing insights into data movement, suspicious activities detected, and any alerts or blocking actions executed. These logs are indispensable for ongoing review, analysis, and compliance auditing.

Overall Conclusion of the "Salla Store" Case Study:

This integrated and comprehensive study demonstrates how "Salla Store" systematically applies the requirements of ISO/IEC 27001 to rigorously protect its information assets. By:

1. **Understanding the Context, Identifying Interested Parties, and Defining the Scope:** The project establishes a clear and fundamental understanding of its security environment and the specific requirements it must address.
2. **Implementing Robust Organizational Controls:** Through the establishment of clear policies, precise definition of roles and responsibilities, strict segregation of duties, and unwavering management support, "Salla Store" builds a solid and sustainable foundation for its information security framework.
3. **Implementing Advanced Data Protection Controls:** Including secure information deletion, effective data masking in non-production environments, and proactive data leakage prevention, "Salla Store" ensures the comprehensive protection of sensitive information throughout its entire lifecycle.

The systematic application of these requirements and controls is instrumental in enabling "Salla Store" to construct a resilient information security management system. This, in turn, significantly enhances customer trust, rigorously protects critical project assets, and ensures continuous compliance with evolving legal and regulatory mandates within the dynamic e-commerce landscape. The diligent presence of the aforementioned evidence for each control and requirement is not merely crucial for ISO/IEC 27001 certification compliance but also foundational for cultivating a strong, security-conscious culture throughout "Salla Store" and for maintaining invaluable customer trust in a highly competitive e-commerce market.